

Week 4: Vendor Risk Remediation

Moving from identifying risks to **fixing and managing them** — with controls, accountability, and time-bound action plans that satisfy HIPAA requirements.

HEALTHCARE SECURITY

THIRD-PARTY RISK



The Remediation Objective



What We're Doing in Week 4

Remediation transforms risk findings into structured action. The goal: **reduce or eliminate** critical security gaps in high-risk vendors by applying controls, assigning ownership, and setting firm deadlines.



Week 3

Identified and scored vendor risks



Week 4

Fix, track, and validate those risks

Step 1: Select High-Risk Vendors

Focus remediation energy on the **two vendors with critical security gaps** — those posing the greatest legal, financial, and patient safety exposure.

Cloud Vendor

Risk: No encryption at rest for ePHI

- Violates HIPAA Security Rule directly
- Data breach impact: severe legal, financial, and reputational consequences



Medical Device Vendor

Risk: No documented Incident Response (IR) Plan

- Delayed response to ransomware or cyberattacks
- Patient safety directly at risk during extended downtime

Step 2: Recommended Security Controls



Multi-Factor Authentication

Both vendors— Require MFA for remote access and admin accounts using authenticator apps or hardware tokens.



ePHI Encryption (AES-256)

Cloud vendor— Encrypt databases and storage buckets at rest. Manage keys via a dedicated KMS.



Incident Response Plan

Medical device vendor— Document detection, containment, and HIPAA breach notification steps. Test annually via tabletop exercises.



Annual HIPAA Risk Assessments

Both vendors— Perform yearly risk analysis. Document vulnerabilities and mitigation steps to maintain ongoing compliance.



Enhanced Logging & Monitoring

Both vendors— Enable access and system logs. Integrate with SIEM tools. Retain logs for **6+ years** per HIPAA best practice.

Step 3: Risk Treatment Strategy

Every identified risk must be assigned a deliberate treatment approach — not every risk is treated the same way.

Mitigate

Implement controls to reduce risk. *Example: Add AES-256 encryption to bring cloud vendor into HIPAA compliance.*

Transfer

Shift risk via insurance or contract. *Example: Require vendor cyber liability insurance; add liability clauses in the BAA.*

Accept

Accept low-impact risks where fix cost exceeds benefit. *Example: Minor logging gaps with compensating controls in place.*

Avoid

Eliminate the risk entirely. *Example: Discontinue use of a persistently non-compliant vendor.*

Step 4: 30–60 Day Remediation Timeline



A time-bound action plan ensures accountability. Each phase builds on the last — from urgent quick wins to deep validation that confirms controls are working.

Deliverable 1: Remediation Plan

A formal document describing every identified risk, its recommended control, the responsible owner, and the resolution deadline.

Vendor	Risk	Control	Due Date
Cloud Vendor	No ePHI encryption at rest	AES-256 encryption + KMS	Day 30
Medical Device Vendor	No Incident Response Plan	Draft & test IR Plan	Day 45
Both Vendors	Weak access controls	Enforce MFA	Day 15

Deliverable 2: Risk Treatment Worksheet

Tracking Every Risk Decision

The Risk Treatment Worksheet documents how each identified risk is handled, the justification for that decision, and its compliance basis. This is an essential audit artifact.

- ⓘ All high-severity risks must include a written justification and a HIPAA regulatory reference to satisfy auditor requirements.

Risk	Severity	Treatment	Justification
No ePHI encryption	High	Mitigate	Required by HIPAA Security Rule §164.312
No IR Plan	High	Mitigate	HIPAA Breach Notification Rule ≤60 days
Minor logging gap	Low	Accept	Compensating controls in place
Non-compliant vendor	Critical	Avoid	No viable path to compliance

Putting It All Together

01

Identify High-Risk Vendors

Select vendors with critical security gaps from Week 3 assessments.

02

Apply Security Controls

Assign MFA, encryption, IR planning, logging, and annual assessments.

03

Decide on Risk Treatment

Mitigate, transfer, accept, or avoid — document and justify each decision.

04

Set Timeline & Accountability

Assign owners and enforce the 30–60 day remediation schedule.

05

Validate & Track Progress

Test controls, conduct tabletop exercises, and confirm HIPAA compliance.

Key Takeaway: Action & Accountability

Not Just Finding Problems

Remediation is where risk management becomes real — controls are implemented, not just recommended.

Fix, Track, Prove

Every action must be documented, assigned, and validated to withstand regulatory scrutiny.

Compliance is Continuous

Annual assessments, ongoing logging, and tested IR plans keep your vendor ecosystem audit-ready year-round.

